Configurazione di un firewall in Pfsense

Questa esercitazione consiste nel configurare un firewall con Pfsense che si interponga tra metasploitable e kali bloccando il traffico di rete sulla porta HTTP (porta 80).

Dopo tantissimi tentativi falliti sono riuscito a trovare una configurazione funzionante, ecco come ho impostato tutte le macchine virtuali e come sono riuscito a far funzionare il firewall.

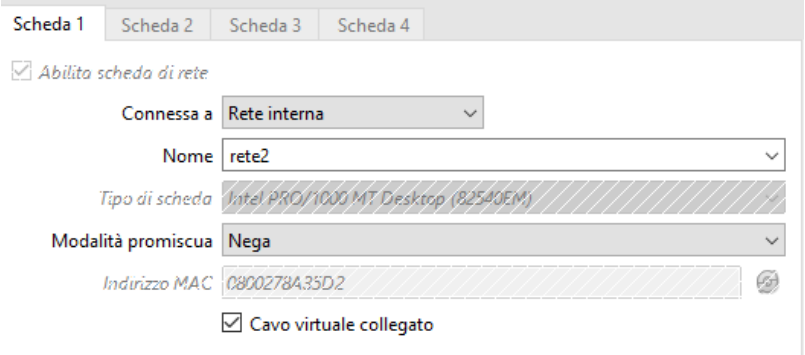
1.Configurazione delle reti nelle macchine virtuali.

La prima cosa da fare è settare bene tutte le reti, per fare in modo che il firewall funzioni e che si metta in mezzo fra kali e DVWA (Damn vulnerable web application di metasploitable) avremo bisogno che kali e metasploitable siano necessariamente su due reti diverse e che pfsense capisca che deve fare da ponte tra queste due reti.

Per fare questo andiamo a vedere le configurazioni delle schede di rete delle macchine virtuali su virtualbox:

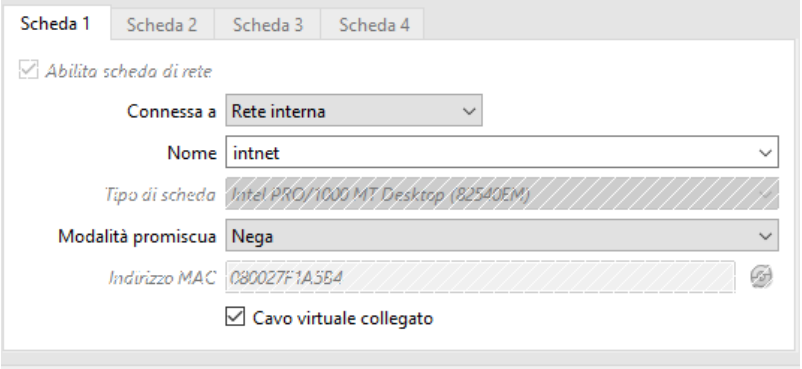
Kali

Rete 1:



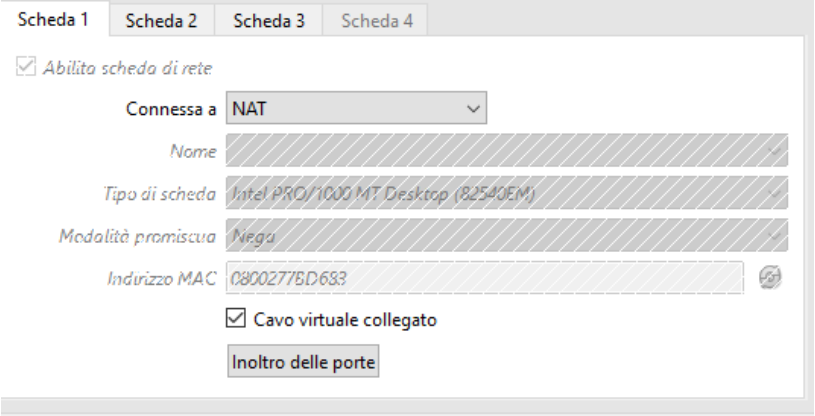
Metasploitable

Rete1:

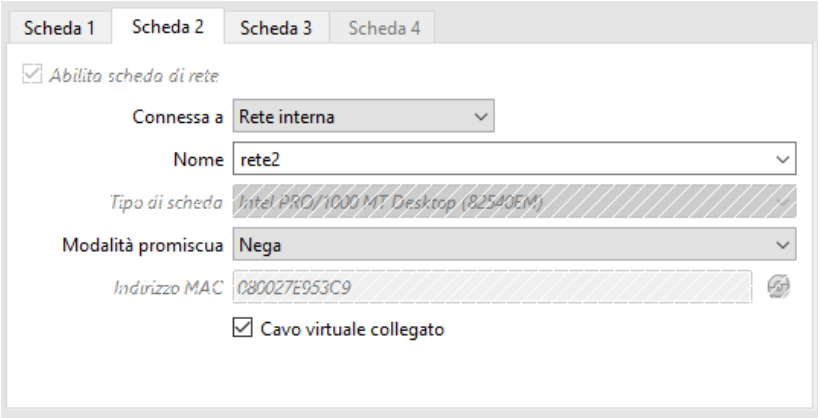


Pfsense

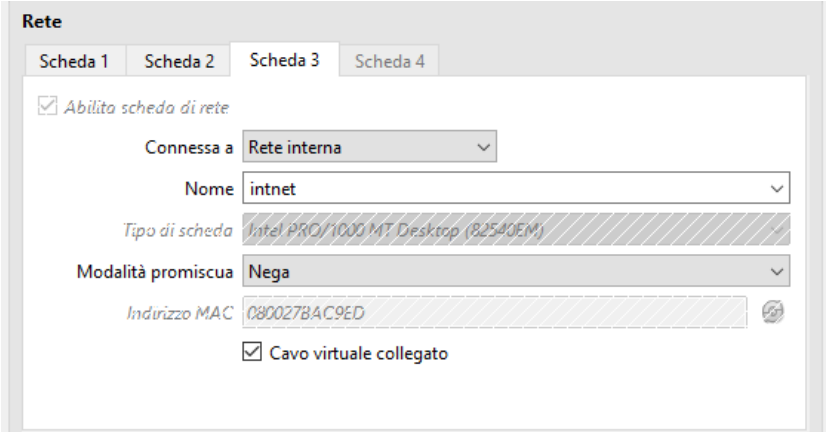
Rete 1:



Rete 2:



Rete 3:



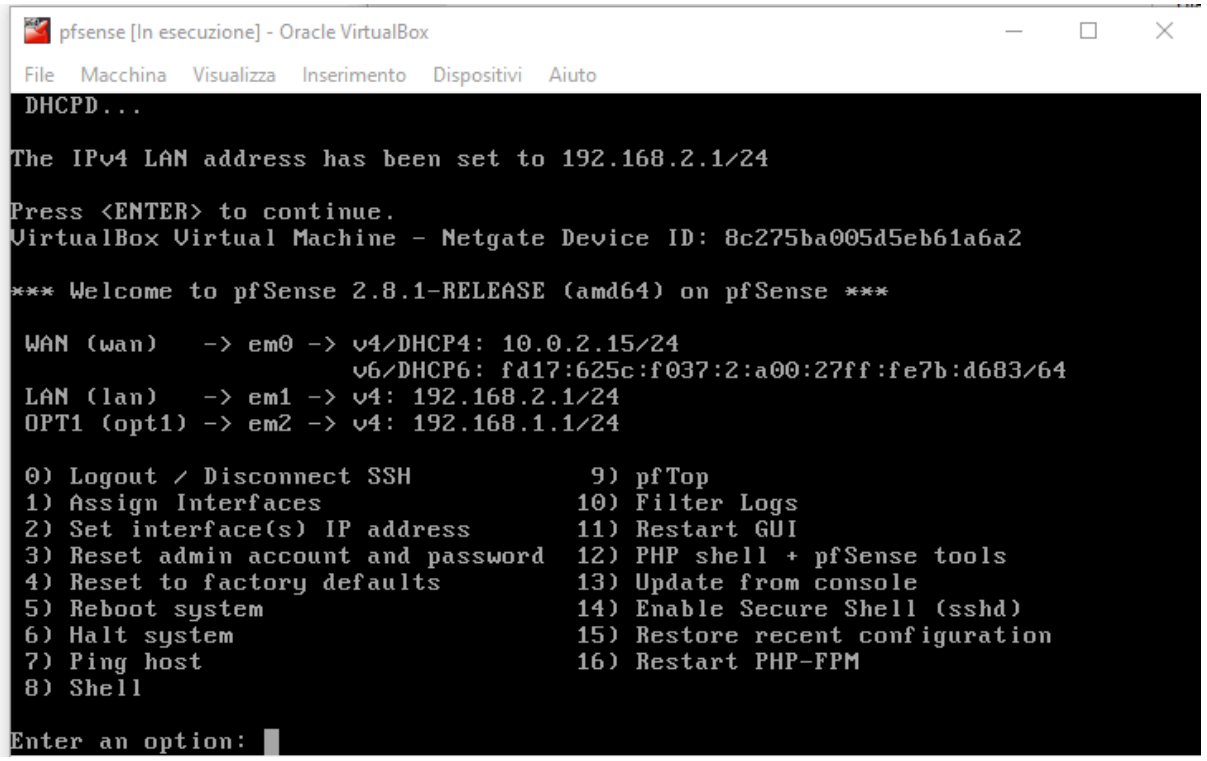
In questo passaggio è molto importante che:

1 Ci siano due reti con nomi diversi, una chiamata **rete2** e una **intnet** che saranno rispettivamente le reti di kali e metasploitable.
2 Sia tutto settato su rete interna.

Configurazione degli indirizzi ip

Ora andremo a configurare gli indirizzi ip sulle varie macchine, una volta fatto questo eseguiremo dei ping da kali per assicurarci che riesca a comunicare con pfsense e metasploitable senza problemi.

Pfsense



Ho impostato tramite il prompt dei comandi e manualmente gli ip delle due reti che mi interessano.

rete2 LAN em1 (Rete di kali)

Ip: 192.168.2.1/24
Gateway: 192.168.2.1/24
DHCP: enabled

intnet OPT1 em2 (Rete di metasploitable)

Ip: 192.168.1.1/24
Gateway: 192.168.1.1/24
DHCP: enabled

Fatto ciò ora Pfsense capirà che si deve mettere come firewall in mezzo a queste due reti.

Kali

Su kali, avendo messo come nome dell'unica rete che ho come "rete2" e avendo già configurato l'ip su pfsense, mi ha in automatico dato un indirizzo ip con il DHCP sulla stessa rete, per controllarlo ho usato il comando **ifconfig**

```
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~/Desktop]
└─$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.2.2  netmask 255.255.255.0  broadcast 192.168.2.255
        inet6 fe80::c560:3376:90c8:17e2  prefixlen 64  scopeid 0x20<link>
        ether 08:00:27:8a:35:d2  txqueuelen 1000  (Ethernet)
        RX packets 41649  bytes 3888593 (3.7 MiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 41185  bytes 3565958 (3.4 MiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

Abbiamo quindi kali su 192.168.2.2.

Metasploitable

Anche qui basta utilizzare il server DHCP per avere un indirizzo ip, per farlo utilizziamo il comando **sudo dhclient eth0** (per eth0 si intende l'interfaccia della rete).
Una volta fatto questo **ifconfig** per vedere l'indirizzo assegnato.

```
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:f1:a5:b4
          inet addr:192.168.1.3  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fef1:a5b4/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3 errors:0 dropped:0 overruns:0 frame:0
          TX packets:45 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:756 (756.0 B)  TX bytes:4950 (4.8 KB)
          Base address:0xd020 Memory:f0200000-f0220000
```

L'indirizzo è 192.168.1.3.

Ping

Controlliamo adesso che sia pfsense che metasploitable funzionino con dei semplici ping verso i loro indirizzi ip.

Pfsense ip 192.168.2.1

```
┌──(kali㉿kali)-[~/Desktop]
└─$ ping 192.168.2.1
PING 192.168.2.1 (192.168.2.1) 56(84) bytes of data.
64 bytes from 192.168.2.1: icmp_seq=1 ttl=64 time=0.248 ms
64 bytes from 192.168.2.1: icmp_seq=2 ttl=64 time=0.244 ms
64 bytes from 192.168.2.1: icmp_seq=3 ttl=64 time=0.281 ms
^C
--- 192.168.2.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2047ms
rtt min/avg/max/mdev = 0.244/0.257/0.281/0.016 ms

┌──(kali㉿kali)-[~/Desktop]
└─$
```

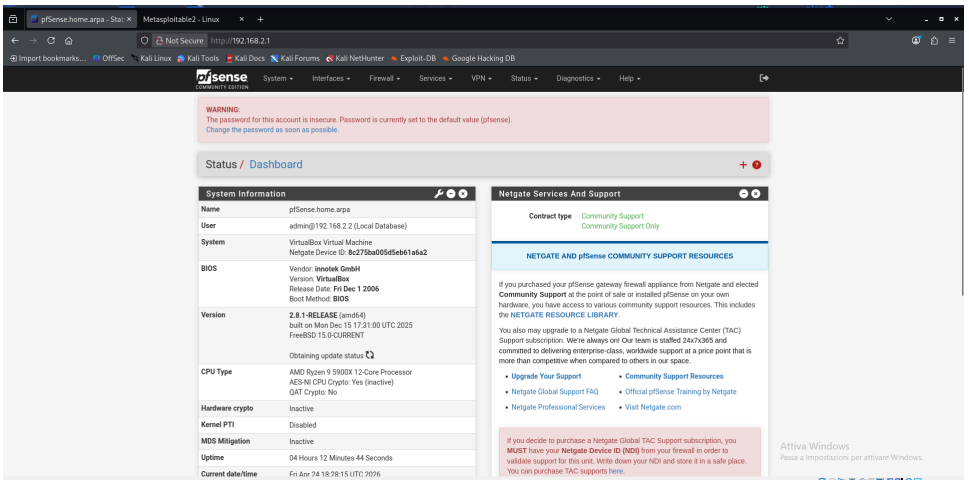
Metasploitable ip 192.168.1.3

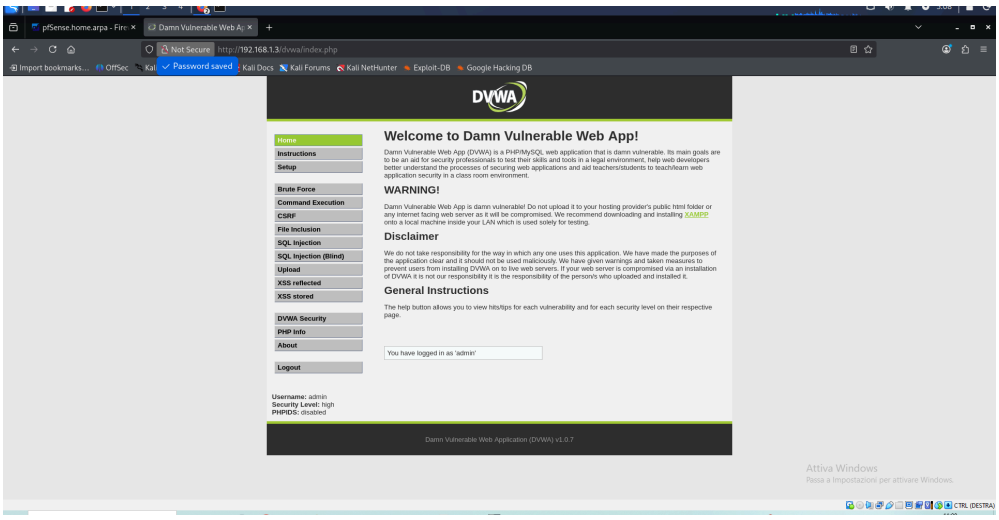
```
┌──(kali㉿kali)-[~/Desktop]
└─$ ping 192.168.1.3
PING 192.168.1.3 (192.168.1.3) 56(84) bytes of data.
64 bytes from 192.168.1.3: icmp_seq=1 ttl=63 time=0.540 ms
64 bytes from 192.168.1.3: icmp_seq=2 ttl=63 time=0.487 ms
64 bytes from 192.168.1.3: icmp_seq=3 ttl=63 time=0.471 ms
^C
--- 192.168.1.3 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2057ms
rtt min/avg/max/mdev = 0.471/0.499/0.540/0.029 ms

┌──(kali㉿kali)-[~/Desktop]
└─$
```

Funziona tutto correttamente, ora passiamo all'ultima parte.

Configurazione del firewall

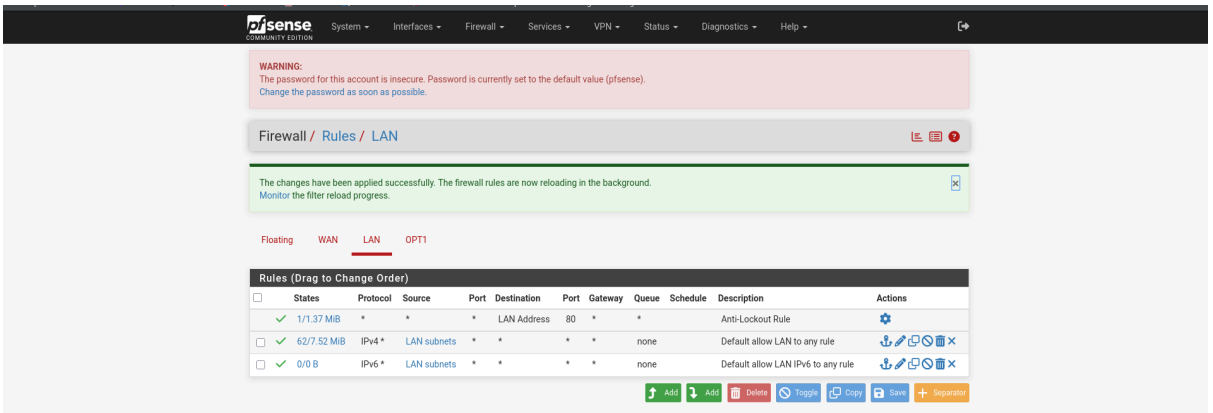
Per prima cosa ho aperto il mio browser e ho digitato nella barra di ricerca l'ip di metasploitable e l'ip di pfsense che ho impostato.



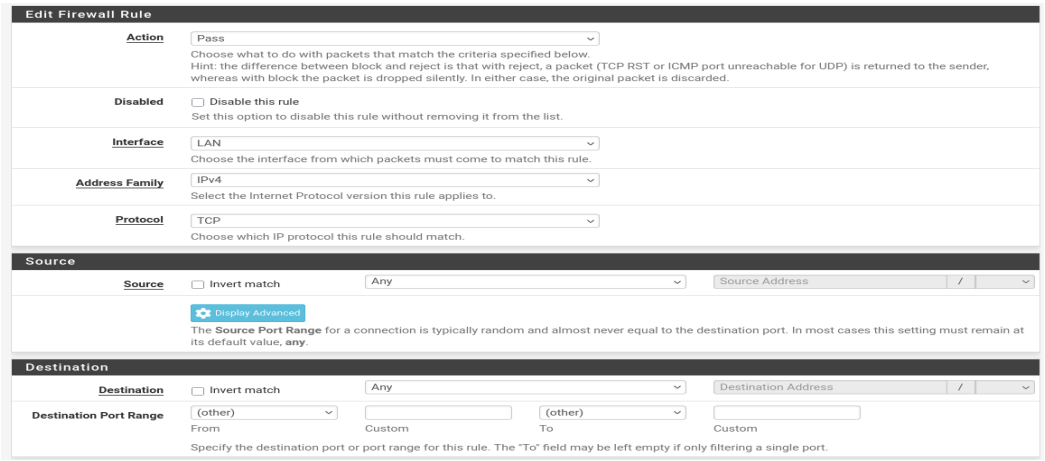


Poi per pfsense sono entrato usando le credenziali e per metasploitable ho cliccato sulla DVWA per poi entrare anche lì con le credenziali.

Ora non ci rimane che impostare il firewall di Pfsense, quindi sono andato su Firewall → rules → LAN (visto che stiamo lavorando su una local area network).
Ho quindi questa schermata:



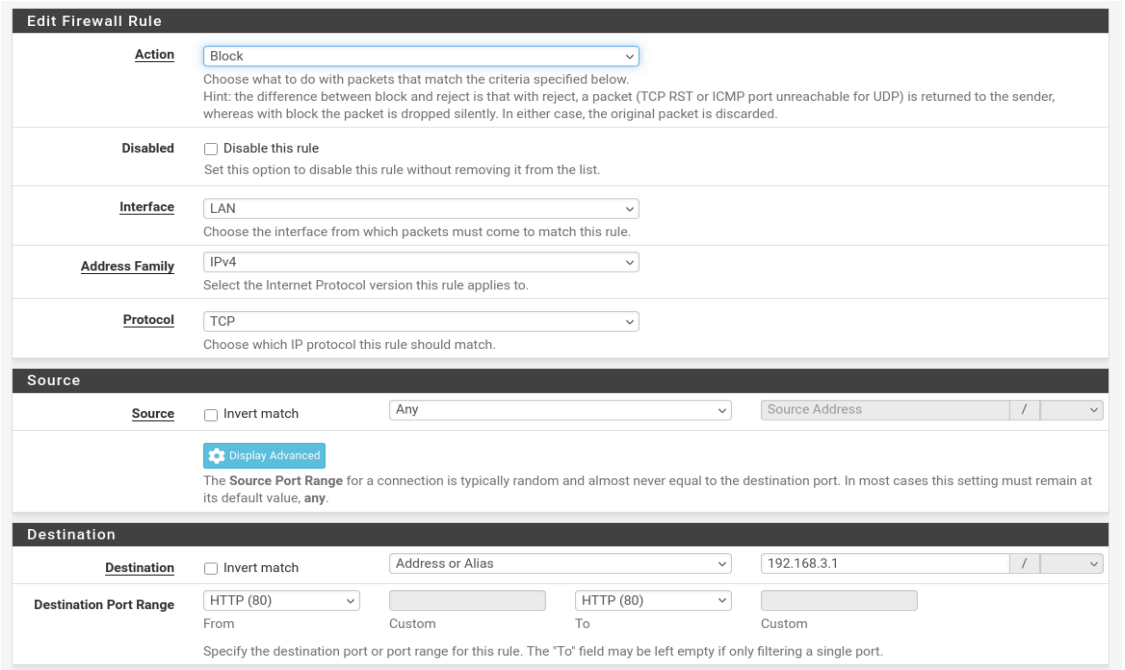
Ora per come è messo il firewall tutto il traffico sta passando, abbiamo bisogno di creare una regola che dica al firewall di bloccare tutto il traffico sulla porta 80 HTTP e su un indirizzo ip specifico: quello di metasploitable che abbiamo impostato in precedenza.
Per farlo andiamo su “add”.



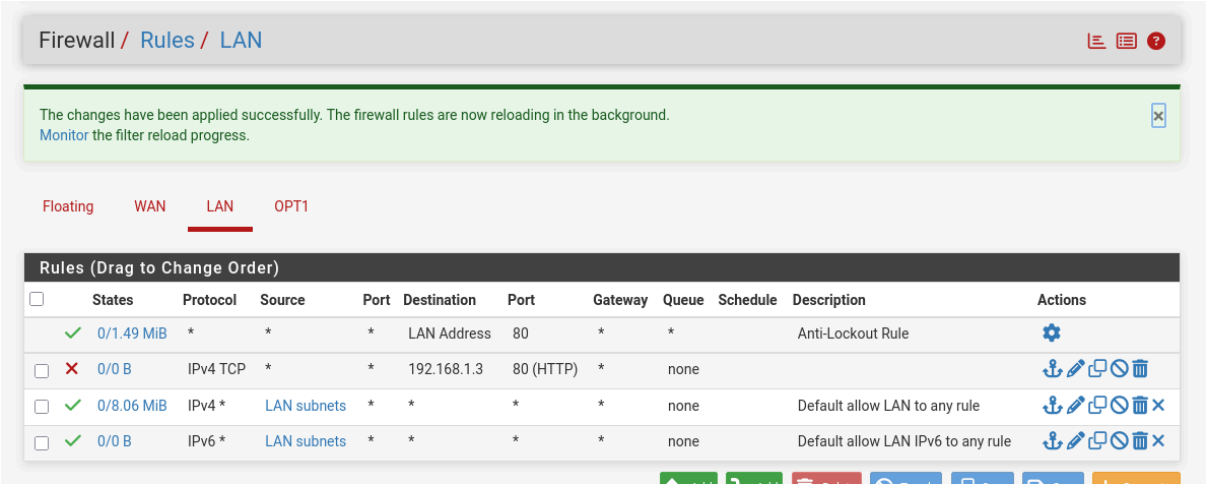
Prima cosa da fare è cambiare **Pass** con **Block** in questa maniera stiamo dicendo alla regola di bloccare il traffico.
Source possiamo lasciare su any.
Destination dobbiamo impostarlo così:

Come vedete gli abbiamo detto di bloccare il traffico sull'indirizzo ip specifico 192.168.1.3, quello di metasploitable, e di bloccare solo i protocolli TCP HTTP sulla porta 80.

Tutta la schermata sarà:

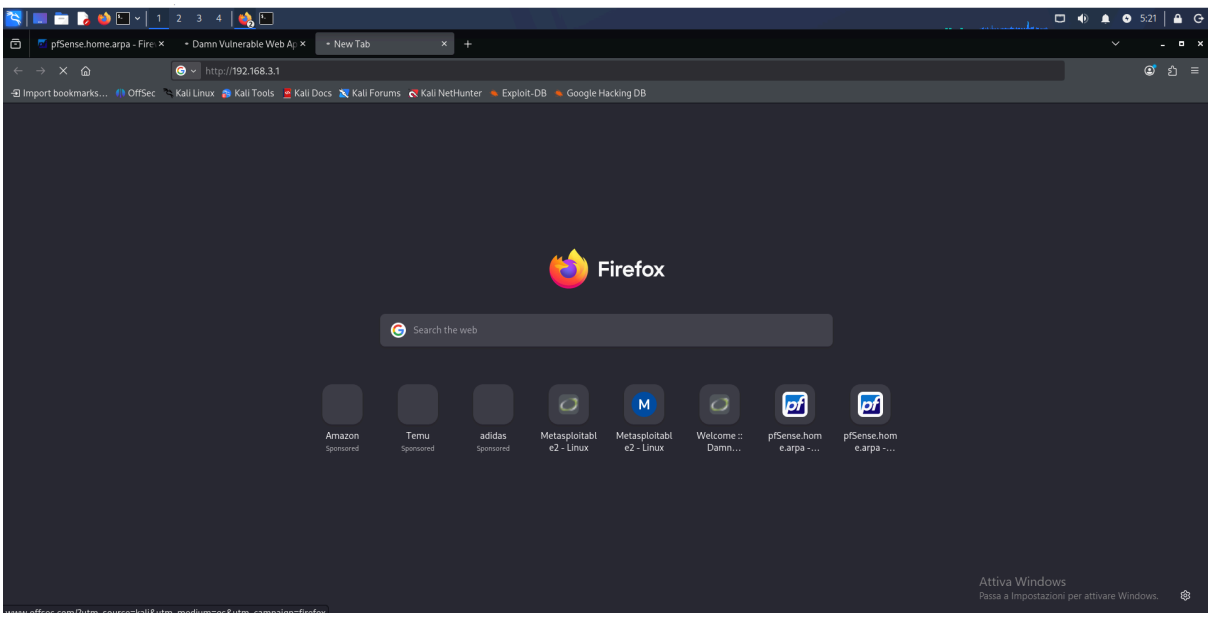


Salviamo.



Ora abbiamo la nostra regola, importante che sia in cima alle altre in maniera tale che venga considerata per prima.
Ultimo passaggio clicchiamo su “apply changes” per salvare.

Bene, cosa succederà ora se proveremo a raggiungere metasploitable o cliccare sulla DVWA da qualunque parte?
Assolutamente nulla, questo perchè il nostro Firewall sta bloccando i protocolli che permettono il corretto funzionamento dei siti.



Continuerà a caricare all’infinito.
Se invece spegnessimo la regola e cliccassimo di nuovo su apply changes funzionerebbe tutto nuovamente.

Ora proviamo effettivamente che il Firewall stia bloccando solo i protocolli HTTP.

La prova

Prima cosa, andiamo a eseguire il ping verso 192.168.1.3 anche con il firewall attivo. Questo ping non funziona con i protocolli TCP quindi dovrebbe andare comunque.

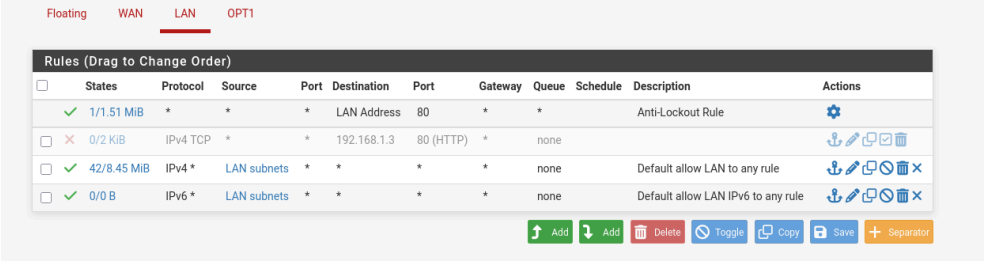
```
┌──(kali㉿kali)-[~/Desktop]
└─$ ping 192.168.1.3
PING 192.168.1.3 (192.168.1.3) 56(84) bytes of data.
64 bytes from 192.168.1.3: icmp_seq=1 ttl=63 time=0.476 ms
64 bytes from 192.168.1.3: icmp_seq=2 ttl=63 time=0.506 ms
64 bytes from 192.168.1.3: icmp_seq=3 ttl=63 time=0.395 ms
64 bytes from 192.168.1.3: icmp_seq=4 ttl=63 time=0.424 ms
^C
--- 192.168.1.3 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3077ms
rtt min/avg/max/mdev = 0.395/0.450/0.506/0.043 ms
```

Perfetto, ora, per vedere invece se i protocolli HTTP funzionano useremo il comando **curl -v**.

```
┌──(kali㉿kali)-[~/Desktop]
└─$ curl -v http://192.168.1.3
*   Trying 192.168.1.3:80 ...
* connect to 192.168.1.3 port 80 from 192.168.2.2 port 50842 failed: Connection timed out
* Failed to connect to 192.168.1.3 port 80 after 133487 ms: Could not connect to server
* closing connection #0
curl: (28) Failed to connect to 192.168.1.3 port 80 after 133487 ms: Could not connect to server
```

Con il firewall attivo ha provato a connettersi e non ce la fa.

Con la regola spenta invece:



Conclusioni

Questo esercizio è servito a capire il funzionamento di un firewall e a insegnarmi a creare una regola al suo interno verificandone poi il suo corretto funzionamento.
E' stato un esercizio pieno di difficoltà, troubleshooting, trial and error, anche solo per capire che dovevo rinominare le reti ci ho messo un po', ma la soddisfazione di vedere metasploitable non funzionare non me la leverà più nessuno.
Se lo scopo era capire tutto il funzionamento degli strumenti che ci sono stati dati e le loro interazioni, a meno che io non mi sia perso qualcosa, penso che ci sia riuscito in pieno.